

Projeto 04A

Unidade Curricular de Segurança

Artur Meireles de Sousa Falcão

a2024130485@isec.pt

2024130485

Data de entrega: 20/04/2026

Tempo de realização: ~3h

1. Terminal AAA-1 foi ligado à rede A (SWA) e foi-lhe atribuído o endereço IP 192.168.1.89 e o endereço MAC 06:23:04:85:aa:03. Tal foi confirmado através do comando “ifconfig”.

```
root@AAA-1:~# ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.1.89 netmask 255.255.255.0 broadcast 0.0.0.0
    inet6 fe80::42:12ff:feed:7200 prefixlen 64 scopeid 0x20<link>
    ether 06:23:04:85:aa:03 txqueuelen 1000 (Ethernet)
    RX packets 4 bytes 1096 (1.0 KB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 9 bytes 726 (726.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING> mtu 65536
    inet 127.0.0.1 netmask 255.0.0.0
    inet6 ::1 prefixlen 128 scopeid 0x10<host>
    loop txqueuelen 1000 (Local Loopback)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 0 bytes 0 (0.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

2. Através dos comandos “netstat -ul” (nomes de serviços) e “netstat -uln” (portos numéricos) confirma-se que o serviço RADIUS está à escuta.

```
root@AAA-1:~# netstat -ul
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
udp        0      0 0.0.0.0:42508           0.0.0.0:*
udp        0      0 localhost:18120         0.0.0.0:*
udp        0      0 0.0.0.0:radius         0.0.0.0:*
udp        0      0 0.0.0.0:radius-acct    0.0.0.0:*
udp6       0      0 [::]:radius            [::]:*
udp6       0      0 [::]:radius-acct       [::]:*
udp6       0      0 [::]:55344             [::]:*

root@AAA-1:~# netstat -uln
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State
udp        0      0 0.0.0.0:42508           0.0.0.0:*
udp        0      0 127.0.0.1:18120         0.0.0.0:*
udp        0      0 0.0.0.0:1812           0.0.0.0:*
udp        0      0 0.0.0.0:1813           0.0.0.0:*
udp6       0      0 :::1812                :::*
udp6       0      0 :::1813                :::*
udp6       0      0 :::55344               :::*
```

3. Através dos comandos “service --status-all” e “uname -a” verificou-se que o sistema é Ubuntu Linux e o serviço ativo é o “freeradius”.

```
root@AAA-1:~# service --status-all
[ + ] freeradius
[ ? ] hwclock.sh
[ - ] procps
[ + ] tacacs_plus
root@AAA-1:~# uname -a
Linux AAA-1 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 x86_64 GNU/Linux
```

Utilizando o editor de texto (“nano /etc/freeradius/3.0/users”), adicionou-se o utilizador “afalcao” com uma password dedicada e uma mensagem de boas-vindas (*Reply-Message*).

```
GNU nano 2.9.3 /etc/freeradius/3.0/users Modified
alice    Cleartext-Password := "gns3"
         Reply-Message = "Hello, ${User-Name}"
bob      Cleartext-Password := "gns3"
         Reply-Message = "Hello, ${User-Name}"
afalcao  Cleartext-Password := "passutilizador"
         Reply-Message = "Bem-vindo, Rei da Rede!!!"
```

4. O router R1 foi registado como cliente autorizado no servidor RADIUS adicionando o seu IP (192.168.1.50) e a chave partilhada "ChaveSecretaR1" ao ficheiro de configuração "/etc/freeradius/3.0/clients.conf".

```
GNU nano 2.9.3 /etc/freeradius/3.0/clients.conf

# sections, or you can re-use a list among multiple "listen" sections.
#
# Un-comment this section, and edit a "listen" section to add:
# "clients = per_socket_clients". That IP address/port combination
# will then accept ONLY the clients listed in this section.
#
#clients per_socket_clients {
#   client socket_client {
#       ipaddr = 192.0.2.4
#       secret = testing123
#   }
#}

client 0.0.0.0/0 {
    secret = gns3
    shortname = all_ipv4_clients
}

client ::0 {
    secret = gns3
    shortname = all_ipv6_clients
}

client 192.168.1.50 {
    secret = ChaveSecretaR1
    shortname = routerR1
}
```

- 5/6. No R1 ativaram-se os processos de log ("debug aaa authentication", "debug aaa authorization" e "debug aaa accounting").

```
R1-0485#debug aaa authentication
AAA Authentication debugging is on
R1-0485#debug aaa authorization
AAA Authorization debugging is on
R1-0485#debug aaa accounting
AAA Accounting debugging is on
```

Configurou-se o servidor RADIUS para autenticação e efetuou-se o comando "test aaa group radius afalcao passutilizador legacy", verificando-se que o teste falha intencionalmente ("No authoritative response"), pois o serviço no AAA-1 ainda não tinha sido reiniciado para ler as alterações.

```
R1-0485#conf t
Enter configuration commands, one per line. End with CNTL/Z.
R1-0485(config)#username arturf secret secretarturf
R1-0485(config)#line con 0
R1-0485(config-line)#privilege level 15
R1-0485(config-line)#exit
R1-0485(config)#aaa new-model
R1-0485(config)#radius server SERVIDOR-AAA1
R1-0485(config-radius-server)#a$4 192.168.1.89 auth-port 1812 acct-port 1813
R1-0485(config-radius-server)#key ChaveSecretaR1
R1-0485(config-radius-server)#exit
R1-0485(config)#aaa authentication login default group radius local
R1-0485(config)#exit

R1-0485#test aaa group radius afalcao passutilizador legacy
Attempting authentication test to server-group radius using radius
No authoritative response from any server.
```

11 -	192.168.1.50	192.168.1.89	06:23:04:85:aa:f1	06:23:04:85:aa:03	RADIUS	Access-Request id=1
12 -	192.168.1.89	192.168.1.50	06:23:04:85:aa:03	06:23:04:85:aa:f1	RADIUS	Access-Reject id=1

7. No servidor AAA-1 executou-se "service freeradius reload" para assumir as configurações. Analisando o script /etc/init.d/freeradius, percebe-se que este comando executa a linha "start-stop-daemon --stop --signal HUP --quiet --pidfile \$PIDFILE", enviando um sinal SIGHUP ao processo para reler os ficheiros sem ir abaixo. O argumento do comando service que permite ver o estado do serviço é o status.

```
GNU nano 2.9.3 /etc/init.d/freeradius

killproc -p "$PIDFILE" || ret=$?
log_end_msg $ret
;;

restart|force-reload)
    configtest || exit 150

    $0 stop
    $0 start
    ;;

reload)
    configtest || exit 150

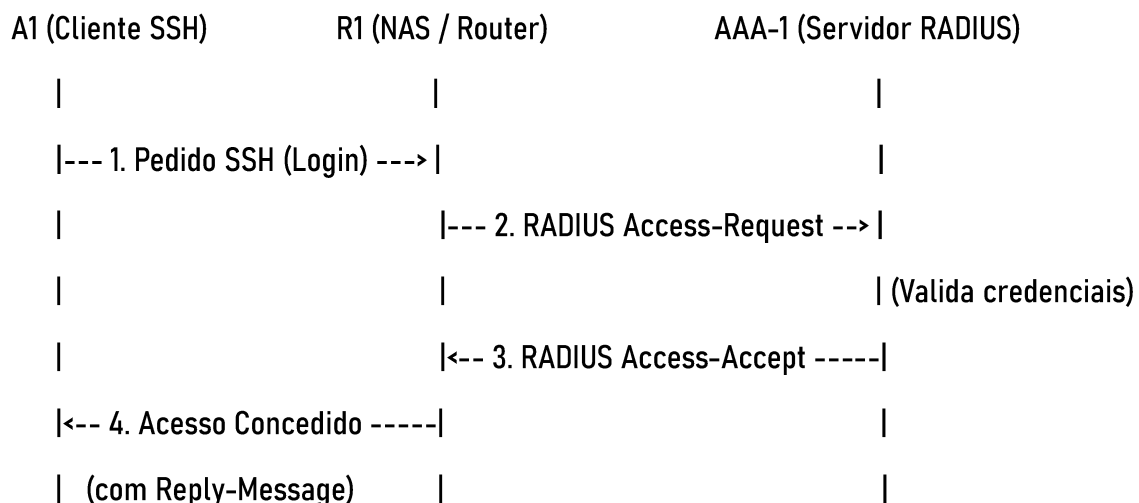
    if status_of_proc -p "$PIDFILE" "$PROG" "$DESCR": then
        log_daemon_msg "Reloading $DESCR" "$PROG"

        start-stop-daemon --stop --signal HUP --quiet --pidfile $PIDFILE || ret=$?
        log_end_msg $ret
    fi
    ;;
```

Em seguida, o acesso SSH do A1 para o R1 foi bem-sucedido, recebendo a mensagem configurada. A password não viaja em *clear text*, sendo ofuscada por uma operação XOR com o hash MD5 da chave secreta e do Request Authenticator, método inspirado no livro *Network Security: Private Communication in a Public World*.

```
42 - 192.168.1.50 192.168.1.89 06:23:04:85:aa:f1 06:23:04:85:aa:03 RADIUS Access-Request id=2
43 - 192.168.1.89 192.168.1.50 06:23:04:85:aa:03 06:23:04:85:aa:f1 RADIUS Access-Accept id=2

Frame 43: Packet, 89 bytes on wire (712 bits), 89 bytes captured (712 bits) on interface -, id 0
  Ethernet II, Src: 06:23:04:85:aa:03 (06:23:04:85:aa:03), Dst: 06:23:04:85:aa:f1 (06:23:04:85:aa:f1)
  Internet Protocol Version 4, Src: 192.168.1.89, Dst: 192.168.1.50
  User Datagram Protocol, Src Port: 1812, Dst Port: 1645
  RADIUS Protocol
    Code: Access-Accept (2)
    Packet identifier: 0x2 (2)
    Length: 47
    Authenticator: 93c7fa5bc62e79213cceb964ee4a1285
    [This is a response to a request in frame 42]
    [Time from request: 412.000 microseconds]
  Attribute Value Pairs
    AVP: t=Reply-Message(18) l=27 val=Bem-vindo, Rei da Rede!!!
      Type: 18
      Length: 27
      Reply-Message: Bem-vindo, Rei da Rede!!!
```



8. Validou-se o cálculo do "Response Authenticator" do pacote "Access-Accept" capturado no Wireshark. Recorrendo ao site Cryptii, simulou-se a fórmula da RFC 2865 (MD5 do Request Authenticator, atributos e chave secreta), obtendo-se exatamente o mesmo *hash* presente no pacote.

The screenshot shows the Cryptii website interface. On the left, under 'VIEW Bytes', the input is a long hexadecimal string. In the center, the 'Hash function' dropdown is set to 'MD5'. On the right, under 'VIEW Bytes', the output is a 16-byte hexadecimal string: 93 c7 fa 5b c6 2e 79 21 3c ce b9 64 ee 4a 12 85.

9. Após a autenticação no terminal A1, o comando "show privilege" confirmou que o utilizador obteve apenas o nível 1 de acesso. A execução do comando "enable" devolveu "% Access denied", comprovando que o RADIUS entregou apenas a *Reply-Message* e não forneceu permissões de administração.

```
(afalcao@192.168.1.50) Password:
Bem-vindo, Rei da Rede!!!
BANNER SEGURANCA
R1-0485>show privilege
Current privilege level is 1
R1-0485>enable
Password:
% Access denied
```

No pacote de pedido (Access-Request), os pares atributo-valor enviados pelo R1 foram: User-Name, User-Password, NAS-Port, NAS-Port-Id, NAS-Port-Type e NAS-IP-Address. Na resposta (Access-Accept), o único par atributo-valor recebido foi a Reply-Message (Tipo 18).

The screenshot shows a Wireshark packet capture of RADIUS traffic. Frame 42 is an Access-Request packet from 192.168.1.50 to 192.168.1.89. It contains several Attribute-Value Pairs (AVPs): User-Name (afalcao), User-Password (encrypted), NAS-Port (2), NAS-Port-Id (tty2), NAS-Port-Type (Virtual), and NAS-IP-Address (192.168.1.50). Frame 43 is an Access-Accept packet from 192.168.1.89 to 192.168.1.50, which contains the Reply-Message (Type 18).

10. Como teste no R1, o comando "privilege level 15" foi aplicado diretamente na configuração das linhas VTY ("line vty 0 4"). Isto resultou num acesso SSH imediato ao nível máximo para qualquer utilizador, contornando o controlo individual. A configuração foi posteriormente retirada.

```
(afalcao@192.168.1.50) Password:
Bem-vindo, Rei da Rede!!!
BANNER SEGURANCA
R1-0485#show privilege
Current privilege level is 15
```

11. A autorização passou a ser feita via RADIUS ativando o comando "aaa authorization exec default group radius" no R1. No ficheiro "users" do AAA-1, adicionou-se o "Service-Type = NAS-Prompt-User" e o "Cisco-AVPair" com o valor "shell:priv-lvl=15". Um novo acesso SSH confirmou a entrada direta no nível 15, e no Wireshark observou-se a entrega do "Vendor-Specific Attribute" com o Vendor ID da Cisco (9), o qual é gerido globalmente pela IANA. A lista atualizada encontra-se no site oficial da IANA, no registo de Private Enterprise Numbers (PEN).

```
GNU nano 2.9.3 /etc/freeradius/3.0/users
alice  Cleartext-Password := "gns3"
      Reply-Message = "Hello, %(User-Name)"
bob    Cleartext-Password := "gns3"
      Reply-Message = "Hello, %(User-Name)"
afalcao Cleartext-Password := "passutilizador"
      Reply-Message = "Bem-vindo, Rei da Rede!!!",
      Service-Type = NAS-Prompt-User,
      Cisco-AVPair = "shell:priv-lvl=15"
```

```
40 - 192.168.1.89 192.168.1.50 06:23:04:85:aa:03 06:23:04:85:aa:f1 RADIUS Access-Accept id=7
4
Frame 40: Packet, 120 bytes on wire (960 bits), 120 bytes captured (960 bits) on interface -, id 0
  Ethernet II, Src: 06:23:04:85:aa:03 (06:23:04:85:aa:03), Dst: 06:23:04:85:aa:f1 (06:23:04:85:aa:f1)
  Internet Protocol Version 4, Src: 192.168.1.89, Dst: 192.168.1.50
  User Datagram Protocol, Src Port: 1812, Dst Port: 1645
  RADIUS Protocol
    Code: Access-Accept (2)
    Packet identifier: 0x7 (7)
    Length: 78
    Authenticator: 339f7491e2def59210b12ba0c7b91f84
    [This is a response to a request in frame 39]
    [Time from request: 481.000 microseconds]
    Attribute Value Pairs
      AVP: t=Reply-Message(18) l=27 val=Bem-vindo, Rei da Rede!!!
        Type: 18
        Length: 27
        Reply-Message: Bem-vindo, Rei da Rede!!!
      AVP: t=Service-Type(6) l=6 val=NAS-Prompt-User(7)
        Type: 6
        Length: 6
        Service-Type: NAS-Prompt-User (7)
      AVP: t=Vendor-Specific(26) l=25 vnd=ciscoSystems(9)
        Type: 26
        Length: 25
        Vendor ID: ciscoSystems (9)
      VSA: t=Cisco-AVPair(1) l=19 val=shell:priv-lvl=15
        Type: 1
        Length: 19
        Cisco-AVPair: shell:priv-lvl=15
```